SRI LANKA INSTITUTE OF INFORMATION TECHNOLOGY

FACULTY OF COMPUTING.

WEB SECURITY- IE2062

IT22121592 – HERATH H.M.C.H.K

Y2S2

Contents

Subdomain Enumeration: 3
Vulnerability title 3
Vulnerability description: 4
Affected components 4
Impact assessment 6
Steps to reproduce: 8
Proposed mitigation or fix: 10

Subdomain ‘design.bigcommerce.com’

Subdomain Enumeration:

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ nslookup design.bigcommerce.com 8.8.8.8
Server:         8.8.8.8
Address:        8.8.8.8#53

Non-authoritative answer:
design.bigcommerce.com  canonical name = bcdesign1.wpengine.com.
Name:   bcdesign1.wpengine.com
Address: 34.83.143.83
```

```
---------------------------------------------------------------------------
+ Target IP:          34.83.143.83
+ Target Hostname:    design.bigcommerce.com
+ Target Port:        443
---------------------------------------------------------------------------
```

Vulnerability title

SSL Verification Failed.

Vulnerability description:

When a system encounters the "SSL Verification Failed" vulnerability issue it usually happens due to the failure in validating the SSL/TLS certificate of a server. This can pose security threats such as man-in-the-middle (MITIM} attacks that allow attackers to intercept and potentially alter the communication, between the client and server.

Important Factors of the Vulnerability:

SSL/TLS protocols depend on certificates that are issued by trusted Certificate Authorities (CA). Failing to validate these certificates could lead to the acceptance of connections, from harmful servers.

Outcomes:

- Attackers can capture data, like usernames and passwords through data interception techniques.
- Manipulating data can be risky as attackers might change the information being sent which could result in vulnerabilities or spreading information.
- Users can be tricked into believing they are interacting with a service even though they are not.

Some typical reasons:

- Using obsolete SSL/TLS libraries, without verification mechanisms can pose a security risk due, to vulnerabilities.
- Misconfiguration occurs when systems are set up incorrectly leading to a lack of enforcement, in certificate validation.
- Relying on self-signed certificates without thorough validation poses risks.

Affected components

The vulnerability known as "SSL Verification Failed" could impact parts of an application or system that are crucial for network communication functions. Here are the main components affected:

Web browsers:

Web browsers are applications that allow users to access and navigate websites on the internet. Web browsers typically act as the layer of protection, for SSL/TLS connections, by verifying certificates failure to do so could potentially put users at risk of encountering harmful websites.

Web servers:

When web servers host applications online they need to make sure they validate SSL certificates, from users properly so that they don't end up trusting harmful certificates by mistake.

APIs:

When using a communication method like HTTPS it is important, for any application programming interface (API) to verify certificates properly to prevent exploitation risks.

Mobile Applications:

Mobile applications that connect to servers located remotely need to ensure they have correct SSL/TLS verification, in place to prevent vulnerabilities from arising due to mishandling or bypassing of certificate validation processes that could leave them open, to attacks.

Microservices:

In microservices setups where services interact through connections are practiced to ensure data integrity and prevent unauthorized access, in the system.

IoT devices:

IoT devices gadgets that depend on SSL/TLS for communication must authenticate certificates properly despite their processing capabilities.

Networking equipment:

Networking devices such, as routers and switches must conduct certificate validation when utilizing SSL/TLS for managing interfaces or securing data transfer.

Third-party libraries and frameworks:

Many software programs rely on libraries, for networking tasks such as cURL and OpenSSL examples). When these libraries lack validation measures in place susceptible, to security risks may be introduced into the programs that depend on them.

Content Delivery Networks (CDNs):

To maintain the security of content delivery Content Delivery Networks (CDNs) need to verify SSL certificates to guarantee the protection and privacy of transmitted data.

Email servers:

Secure email services that utilize protocols such as SMTPS and IMAPS are required to verify SSL certificates to ensure the security of email communication and prevent interception of data.

Impact assessment.

When discussing the issue of the "SSL Verification Failed" vulnerability, in relation to business operations and security measures online is important to grasp its significance. This vulnerability can lead to consequences of significance. Comprehending them is vital for any organization dependent, on secure digital communications.

Potential for Data Breach:

Just picture this scenario; What if important information such, as credit card numbers of customers and personal details were to be accessed by a hacker due to the system not correctly verifying SSL certificates? This could result in data breaches that jeopardize the security of everyone's information. Moreover, if malicious entities could tamper with this data it might cause disruptions ranging from scams, to undermining trust among individuals.

Reputational damage:

Consider the repercussions of such a situation. If clients discover that their information is not secure they may start to doubt the credibility of the company. This lack of trust could result in feedback and adverse publicity that may persist over a prolonged period. Word spreads quickly in **today's** era of advancements as people tend to share news.

The Impact on Finances:

Looking at it from a money standpoint can get overwhelming fast for companies dealing with data protection rules such, as GDPR and HIPAA. They might end up with penalties for noncompliance. Could even face legal costs if people affected choose to take steps against them. Aside, from that aspect, it's also important to consider the money spent on addressing vulnerabilities. This includes updating systems carrying out checks and managing incidents which all demand both time and resources.

The Effects on Operations:

When a security weakness is taken advantage of it can cause disruptions, in services that customers use leading to feelings of annoyance and dissatisfaction with the situation at hand. During events, the company's attention moves away from day-to-day tasks, towards managing the fallout which in turn can reduce efficiency and affect the company's overall objectives.

Challenges with Regulations and Compliance:

Organizations could face monitoring, by bodies in case of a breach stemming from SSL/TLS problems leading to additional compliance checks and potential penalties for violations.

The enduring strategic implications:

A company’s reputation may suffer in the run due, to security problems; it could damage trust with both partners and customers who may seek alternatives if they perceive their information as being, at risk of exposure or breach – ultimately affecting the organization's standing in the market and competitive edge.

Technical debt:

Finally comes the issue of debt where companies might have to spend resources on updating systems that do not meet today's security requirements—a task that can be both expensive and time-intensive.

Steps to reproduce:

```
└─$ dig design.bigcommerce.com @8.8.8.8

; <<>> DiG 9.19.21-1-Debian <<>> design.bigcommerce.com @8.8.8.8
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 46381
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;design.bigcommerce.com.                IN      A

;; ANSWER SECTION:
design.bigcommerce.com. 900     IN      CNAME   bcdesign1.wpengine.com.
bcdesign1.wpengine.com. 120     IN      A       34.83.143.83

;; Query time: 88 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Fri Oct 18 15:22:41 +0530 2024
;; MSG SIZE  rcvd: 100
```

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ nslookup design.bigcommerce.com 8.8.8.8
Server:         8.8.8.8
Address:        8.8.8.8#53

Non-authoritative answer:
design.bigcommerce.com  canonical name = bcdesign1.wpengine.com.
Name:   bcdesign1.wpengine.com
Address: 34.83.143.83
```

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ curl -v https://design.bigcommerce.com
* Host design.bigcommerce.com:443 was resolved.
* IPv6: (none)
* IPv4: 34.83.143.83
*   Trying 34.83.143.83:443...
* Connected to design.bigcommerce.com (34.83.143.83) port 443
* ALPN: curl offers h2,http/1.1
* TLSv1.3 (OUT), TLS handshake, Client hello (1):
*  CAfile: /etc/ssl/certs/ca-certificates.crt
*  CApath: /etc/ssl/certs
* TLSv1.3 (IN), TLS handshake, Server hello (2):
* TLSv1.3 (IN), TLS handshake, Encrypted Extensions (8):
* TLSv1.3 (IN), TLS handshake, Certificate (11):
* TLSv1.3 (IN), TLS handshake, CERT verify (15):
* TLSv1.3 (IN), TLS handshake, Finished (20):
* TLSv1.3 (OUT), TLS change cipher, Change cipher spec (1):
* TLSv1.3 (OUT), TLS handshake, Finished (20):
* SSL connection using TLSv1.3 / TLS_AES_256_GCM_SHA384 / X25519 / RSASSA-PSS
* ALPN: server accepted h2
* Server certificate:
*  subject: CN=*.wpengine.com
*  start date: Aug  2 00:00:00 2024 GMT
*  expire date: Sep  2 23:59:59 2025 GMT
*  subjectAltName does not match design.bigcommerce.com
* SSL: no alternative certificate subject name matches target host name 'design.bigcommerce.com'
* Closing connection
* TLSv1.3 (OUT), TLS alert, close notify (256):
curl: (60) SSL: no alternative certificate subject name matches target host name 'design.bigcommerce.com'
More details here: https://curl.se/docs/sslcerts.html
```

```
---------------------------------------------------------------------------
+ Target IP:          34.83.143.83
+ Target Hostname:    design.bigcommerce.com
+ Target Port:        443
---------------------------------------------------------------------------
```

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ wget https://design.bigcommerce.com/js/app.js
--2024-10-18 15:33:00--  https://design.bigcommerce.com/js/app.js
Resolving design.bigcommerce.com (design.bigcommerce.com)... 34.83.143.83
Connecting to design.bigcommerce.com (design.bigcommerce.com)|34.83.143.83|:443... connected.
The certificate's owner does not match hostname ‘design.bigcommerce.com’
```

Proposed mitigation or fix:

To effectively tackle the vulnerability of "SSL Verification Failed " companies can put into practice mitigation tactics, for security enhancement purposes. Here is a user-friendly explanation of the suggested solutions;

Ensure that certificate validation is implemented consistently and rigorously:

Make sure that all programs and systems thoroughly verify SSL/TLS certificates, including validating the certificate chain to ensure it is issued by a trusted Certificate Authority (CA).

Update software and libraries:

Make sure to keep all your software and libraries that manage SSL/TLS communications up, to date this includes web servers; APIs, mobile apps, and any third-party tools such, as OpenSSL and cURL to make sure they have the newest security updates installed.

Ensure the use of encryption protocols:

Make sure to set up your systems with cipher suites and turn off insecure protocols (such, as SSL 2.

Make sure to utilize certificates:

Make sure to go for certificates, from known and trusted Certificate Authorities (CA). Try to steer off using self-signed certificates in working environments unless it's really required and if you have to use them make sure they are properly validated.

Activate Certificate Pinning:

It's an idea to include certificate pinning in your applications for mobile and web apps. This approach enables apps to store certificates or public keys to fend off MIT attacks.

Ensure to conduct of security checks on the basis:

Make sure to perform security evaluations and inspections to uncover any SSL/TLS setup issues which can help detect vulnerabilities before they are exploited.

Keep an eye on when your certificate expires:

Make sure you keep an eye on when certificates are about to expire and set up alerts, for renewing them in time to prevent any disruptions, in services caused by expired certificates.

Ensure that the staff members are properly trained and informed:

Ensure that developers and IT personnel undergo training and awareness initiatives, on the significance of SSL/TLS and certificate validation to prevent misconfigurations and security oversights within your team.

Make use of security tools:

Make use of automated security tools to check for vulnerabilities linked to SSL/TLS setup configuration settings as these tools can pinpoint configurations and notify teams, about problems.

Develop a plan for responding to incidents:

Ensure you have a defined plan, for addressing incidents related to SSL/TLS that encompasses protocols for resolving issues and communicating effectively while minimizing the impact of any security breaches.